

Периметр сети под прицелом: Как Red Team находит дыры в вашей защите до того, как это сделают хакеры

 redsec.by/article/perimetr-seti-pod-pricelom-kak-red-team-nahodit-dyry-v-vashej-zashite-do-togo-kak-eto-sdelayut-hakery

Red Teams | 23 декабря 2025



Граница, которая всегда под ударом

В 2025 году понятие «сетевого периметра» окончательно трансформировалось. Если десять лет назад это была четкая линия, охраняемая железным файрволом, то сегодня это диффузная среда, включающая облачные сервисы, удаленные рабочие места, API микросервисов и мобильные точки доступа. Представьте ваш периметр как границу государства. Файрвол — это таможня и пограничная служба. Но что, если на границе есть заброшенные тропы, о которых забыло командование, или охранники, использующие одинаковые ключи для всех ворот?

Red Team (Красная команда) — это элитное подразделение проверяющих, которые имитируют действия реальных APT-группировок и киберпреступников. В отличие от классических аудиторов, которые сверяют настройки по чек-листам, мы действуем творчески и агрессивно. Наша задача — не просто «найти уязвимость», а «прорваться внутрь». Внешний пентест периметра сети (External Perimeter Penetration Testing, EPPT) — это наиболее эффективный способ обнаружить слепые зоны защиты до того, как в них проскользнет реальный враг.

В этой статье мы пройдем весь путь профессионального взлома периметра: от разведки по открытым источникам до захвата контроллера домена, и разберем, как

типичные ошибки системных администраторов превращаются в пригласительный билет для шифровальщиков.

Часть 1: Сетевой периметр и психология Red Team

Почему ваш фаервол вас не спасает?

Сетевой периметр — это совокупность всех внешних точек соприкосновения вашей организации с интернетом. Большинство компаний полагают, что они знают свои активы. Однако реальность такова: в 70% случаев Red Team находит ресурсы, которые не числятся в инвентаризационных списках ИТ-отдела.

Теневые ИТ (Shadow IT) — главная проблема современности:

- **Забытые дев-серверы:** Разработчик поднял инстанс в AWS для теста новой фичи, использовал реальный дамп БД и забыл его удалить.
- **Открытые порты для «удобства»:** Системный администратор временно открыл RDP (3389) для удаленного фикса в выходной день и оставил правило активным на месяцы.
- **Устаревшие VPN-шлюзы:** Старые устройства, которые не обновлялись два года, потому что «работает — не трогай».

Red Team против обычного аудита

Обычный аудит — это взгляд изнутри. Red Team смотрит на компанию глазами внешнего врага, у которого нет схем вашей сети. Мы начинаем с нуля, и именно этот подход позволяет находить самые критические бреши. Мы не верим документации; мы верим только тому, что отвечает на наши запросы в порты 80, 443 или 3389.

Часть 2: Пятиступенчатый алгоритм прорыва периметра

Методология Red Team — это строгая последовательность действий, где каждый этап подготавливает почву для следующего.

Стадия 1: OSINT (Open Source Intelligence) — Скрытая разведка

На этом этапе мы не отправляем ни одного пакета в сторону ваших серверов. Мы собираем информацию из публичных источников.

Механика разведки:

- **Поиск инфраструктуры:** С помощью сервисов вроде Shodan, Censys, Amass и crt.sh мы выявляем поддомены (subdomain enumeration). Поддомены вроде dev.company.by, staging-api.company.com или test-vpn.company.by — наши приоритетные цели.
- **Анализ DNS:** Мы проверяем записи MX (почта), TXT (верификации), SPF/DMARC. Иногда записи TXT содержат ключи верификации сервисов, которые дают подсказки о стеке технологий.
- **Социальная инженерия и GitHub:** Мы ищем профили ваших разработчиков. Часто в публичных репозиториях по ошибке остаются .env файлы с паролями от БД или API-ключами, которые работают на внешних серверах.

Кейс из практики (2024): В случае с компанией Zscaler атакующие обнаружили тестовый сервер, просто перебирая поддомены test-*.zscaler.com. Сервер был заброшен, но на нем хранились актуальные сертификаты и ключи, что позволило IntelBroker продать данные за \$20,000.

Стадия 2: Сканирование портов — Картирование «боевой зоны»

Теперь мы начинаем «простукивать» стены. Основной инструмент здесь — Nmap. Мы ищем не просто открытые порты, а сервисы, которые за ними стоят.

Программный код сканирования:

```
# Идентификация версий и запуск безопасных скриптов по списку IP
nmap -sV -sC -Pn -f --mtu 24 195.34.80.0/24
```

```
# Тотальный перебор всех портов (включая высокие) на критических узлах
nmap -p- -T4 -A target.company.by
```

Флаг -f и --mtu используются для фрагментации пакетов, что иногда позволяет обходить примитивные системы обнаружения вторжений (IDS).

Что мы находим чаще всего:

- **22 (SSH):** Потенциальный доступ к консоли.
- **80, 443, 8080, 8443:** Веб-приложения и панели управления.
- **3389 (RDP):** Прямой путь к захвату Windows-сервера.
- **3306 (MySQL), 5432 (PostgreSQL):** Базы данных, торчащие наружу (критическая ошибка!).

Стадия 3: Banner Grabbing и анализ версий — Поиск слабого звена

Мы подключаемся к порту и смотрим на «ответ» сервера. Это называется «захват баннера».

Пример баннера:

HTTP/1.1 200 OK
Server: Apache/2.4.29 (Ubuntu)
X-Powered-By: PHP/7.4.3

Для эксперта Red Team это звучит так: «У меня старый Apache и древний PHP, для которых в Metasploit есть десяток готовых эксплойтов». Мы также анализируем SSL-сертификаты. Например, если CN: internal-dev-01.local, мы узнаем внутреннюю структуру именования хостов компании.

Реальный пример (Redis, октябрь 2025): Обнаружение открытого инстанса Redis без пароля (уязвимость CVE-2025-49844). Исследования показали, что более 60,000 инстансов в мире доступны без аутентификации. Red Team просто подключается и выполняет FLUSHALL или крадет все сессии пользователей.

Стадия 4: Активная эксплуатация — Штурм

Когда цель определена, начинается активная фаза.

4.1 Брут-форс (Перебор паролей)

Если мы видим RDP или VPN без MFA (многофакторной аутентификации), мы запускаем Hydra.

Статистика RansomHub (ноябрь 2024): Хакеры атаковали RDP-сервер в течение 15 дней. Было совершено более 2 миллионов попыток входа с использованием 137,500 уникальных юзернеймов. В итоге пароль Company123 был подобран за 4 часа.

4.2 Эксплуатация Веб-приложений

Мы ищем SQL-инъекции.

```
# Пример атаки на форму логина
Username: ' OR '1'='1
Password: anything
```

Если разработчик не фильтрует входные данные, SQL-запрос `SELECT * FROM users WHERE login = " OR '1'='1'` вернет нам доступ с правами администратора.

4.3 Дефолтные учетные данные

Это классика. Огромное количество систем (Tomcat, Jenkins, Webmin) устанавливаются с паролями admin/admin или root/root.

Tomcat Manager: Дает возможность загрузить .war файл, который по сути является бэкдором (webshell), дающим полный доступ к серверу.

Стадия 5: Lateral Movement — Боковое движение

Прорвать периметр — это только 20% работы. Настоящая цель Red Team — данные внутри. Получив доступ к одному серверу, мы начинаем «осматриваться»:

- Ищем пароли в файлах конфигурации.
- Дампим память процесса LSASS для получения хэшей паролей пользователей.
- Сканируем внутреннюю сеть (которая часто не защищена так же хорошо, как внешняя).

Часть 3: Анатомия провала — Топ-5 ошибок конфигурации

Ошибка 1: «Забытые» тестовые стенды

Это самая частая находка. Сервер, созданный для двухнедельного теста, живет годами. Он не обновляется, на нем нет антивируса, и он часто имеет доступ как в интернет, так и во внутреннюю сеть компании.

Ошибка 2: RDP в интернет без защиты

Публикация порта 3389 без использования VPN или шлюза RD Gateway — это приглашение для шифровальщиков. Даже если пароль сложный, существуют уязвимости (вроде BlueKeep), позволяющие захватить сервер без пароля.

Ошибка 3: Слабые политики VPN

VPN — это дверь в ваш дом. Если на этой двери замок, который открывается любой шпилькой (слабый пароль вроде VPN2025), то вся ваша внутренняя защита бесполезна. Отсутствие MFA (второго фактора) сегодня считается критическим нарушением безопасности.

Ошибка 4: Чрезмерно разрешающие правила файрвола (Any-Any)

Часто администраторы, устав от жалоб пользователей на «неработающие доступы», создают правила Source: Any -> Destination: Internal_Server -> Port: Any. Это дыра, через которую пройдет любой вирус.

Ошибка 5: Отсутствие Egress-фильтрации (исходящий трафик)

Большинство компаний следят за тем, кто входит в сеть, но никто не следит за тем, что из нее выходит. Если хакер заразил сервер, он должен передать данные на свой C2-сервер (Command & Control). Если исходящий трафик не ограничен, данные утекут незаметно.

Часть 4: Связь с требованиями ОАЦ РБ (Беларусь)

Для белорусских организаций аудит сетевого периметра — это не только забота о безопасности, но и выполнение требований законодательства. Технический регламент **ТР 2013/027/BY** и стандарты ОАЦ жестко регламентируют меры по межсетевому экранированию.

Таблица соответствия: Ошибки vs Требования ОАЦ

Объект аудита	Типичное нарушение	Соответствие ТР 2013/027/BY
Учет активов	Наличие незадокументированных тестовых серверов	Нарушение требования об инвентаризации информационных систем
Управление доступом	Открытый RDP (3389) без VPN	Нарушение регламента обеспечения удаленного доступа
Аутентификация	Отсутствие MFA на внешних шлюзах	Нарушение требований по многофакторной аутентификации
Сегментация	Отсутствие DMZ (демилитаризованной зоны)	Нарушение принципа разделения сетей разных уровней доверия
Патч-менеджмент	Использование уязвимых версий сервисов (Apache, Nginx)	Нарушение требований по управлению уязвимостями

Как Red Team доказывает нарушения: Мы не просто пишем в отчете «у вас нет сегментации». Мы показываем скриншот: «Мы зашли через тестовый веб-сервер и через 15 минут получили доступ к базе данных с персональными данными клиентов в закрытом сегменте». Это делает отчет неоспоримым аргументом для руководства.

Часть 5: Дорожная карта укрепления периметра

Если вы не хотите, чтобы Red Team (или реальные хакеры) захватили вашу сеть за один рабочий день, внедрите следующие меры:

- **Инвентаризация 2.0:** Используйте инструменты непрерывного мониторинга активов (EASM). Вы должны знать о каждом новом IP-адресе в течение часа после его появления.
- **Тотальный VPN + MFA:** Закройте все порты управления (SSH, RDP, WinRM) внутри VPN. Внедрите аппаратные ключи (Yubikey) или TOTP-коды.
- **Принцип «Default Deny»:** Сначала запретите всё, а затем открывайте только те порты, которые жизненно необходимы для бизнеса.
- **Микросегментация:** Даже внутри вашей сети серверы не должны «видеть» друг друга, если им это не нужно для работы.
- **Логирование в SIEM:** Файрвол должен не просто блокировать пакеты, он должен «кричать» об атаке. Если с одного IP идет 1000 попыток входа в минуту — это повод для автоматической блокировки.
- **Регулярный пентест:** Проводите Red Team аудит минимум раз в полгода. Ландшафт угроз меняется слишком быстро, чтобы полагаться на прошлогоднюю проверку.

Аудит сетевого периметра от Red Team — это не просто проверка «закрыты ли двери». Это полноценная симуляция боевых действий, которая выявляет реальную готовность вашей ИТ-команды к отражению угроз. В 2025 году вопрос не в том, «взломают ли вас», а в том, «когда это произойдет и насколько вы будете к этому готовы».

Помните: хакеры тратят недели на изучение ваших слабостей. Red Team делает то же самое, но дает вам шанс исправить ошибки до того, как они превратятся в катастрофу.